

# Week 4 -Cyber Kill Chain Analysis: Storm-0501 and WinRM (T1021.006)

Course: Cyber Threat Intelligence · Students: Aruzhan Abdulina, Kanasheva Darina · Sep 30, 2026

## 1. Case selection and scope

This report maps the ransomware group Storm-0501 onto the seven stages of the Lockheed Martin Cyber Kill Chain and ties each stage to MITRE ATT&CK techniques, with T1021.006 (Windows Remote Management) as the anchor. It continues the Week 2 (OSINT) and Week 3 (MISP) work on the same topic.

The case is built from three sources: the [MITRE ATT&CK group page G1053](#), the Microsoft Threat Intelligence report of [26 September 2024](#) (referred to below as MS-2024), and the report of [27 August 2025](#) (MS-2025).

The two Microsoft reports describe two different campaigns, so the chain below is a composite of both:

- **MS-2024 (hybrid, on-premises ransomware):** initial access through unpatched public-facing servers, Cobalt Strike and Impacket for credential theft and movement, Rclone exfiltration, and Embargo ransomware pushed by a scheduled task created through Group Policy.
- **MS-2025 (cloud-based ransomware):** the actor already held domain administrator rights; Evil-WinRM was used for lateral movement and discovery, followed by a pivot into Entra ID and Azure, data theft with AzCopy, mass deletion of backups, and extortion. No ransomware binary was deployed in this campaign.

One correction to the Week 2 report: MS-2025 places Evil-WinRM **after** domain administrator access was obtained, as a lateral-movement tool. It was not the initial-access vector. The Week 2 wording "initial access via WinRM" should therefore be read as "post-compromise access via WinRM".

## 2. Kill Chain overview

The Cyber Kill Chain was introduced by Hutchins, Cloppert and Amin in the Lockheed Martin paper *Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains* (2011). It describes an intrusion as seven sequential phases, and the authors argue that defenders win by breaking the chain at any single phase.

1. **Reconnaissance:** the attacker researches and selects targets.
2. **Weaponization:** the attacker couples an exploit with a payload or backdoor.
3. **Delivery:** the weapon is transmitted to the target.
4. **Exploitation:** the exploit triggers and gives code execution on the victim.
5. **Installation:** a persistent foothold is placed on the victim.
6. **Command and Control (C2):** a channel is opened so the attacker can operate remotely.
7. **Actions on Objectives:** the attacker carries out the goal, such as data theft, destruction or extortion.

The paper pairs each phase with a course-of-action matrix (detect, deny, disrupt, degrade, deceive, destroy), which is used in Section 6.

### 3. Stage-by-stage mapping

Six of the seven stages are documented in the sources; only Reconnaissance is inferred. Technique IDs were taken from the [MITRE G1053 page](#) (ATT&CK v19.2, group page last modified 31 July 2026), except T1595.002, which is added by us.

| Kill Chain stage  | What Storm-0501 did                                                                                                                                                                                                                                                                | Source                                                                    | ATT&CK techniques                                                                                                         | Basis      |
|-------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|------------|
| 1. Reconnaissance | Target selection is not described directly. Microsoft calls the targeting opportunistic and says access came via brokers or unpatched public-facing servers, which implies scanning for exposed services.                                                                          | <a href="#">MS-2025</a> (intro), <a href="#">MS-2024</a> (Initial access) | T1595.002<br>Vulnerability Scanning                                                                                       | Inferred   |
| 2. Weaponization  | Obtained exploits for known flaws in Zoho ManageEngine (CVE-2022-47966), Citrix NetScaler (CVE-2023-4966) and ColdFusion (CVE-2023-29300 or CVE-2023-38203). Used off-the-shelf tools (Cobalt Strike packed with Themida, Impacket, Rclone, Evil-WinRM, AADInternals, AzureHound). | <a href="#">MITRE G1053</a> , MS-2024                                     | T1588.006<br>Obtain Capabilities;<br>Vulnerabilities; T1027.002<br>Software Packing;<br>T1587.003<br>Digital Certificates | Documented |

| Kill Chain stage | What Storm-0501 did                                                                                                                                                                                          | Source                                      | ATT&CK techniques                                                                                                                         | Basis      |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|------------|
|                  | Rented ransomware (Embargo) as an RaaS affiliate.                                                                                                                                                            |                                             |                                                                                                                                           |            |
| 3. Delivery      | Reached the first host by exploiting unpatched public-facing servers, through access brokers (Storm-0249, Storm-0900), or with possibly stolen credentials. Brute force was assessed with medium confidence. | MS-2024 (Initial access)                    | T1190 Exploit Public-Facing Application; T1078 Valid Accounts; T1110 Brute Force                                                          | Documented |
| 4. Exploitation  | The exploit gave code execution and administrative privileges on the device. The actor then ran hands-on discovery with systeminfo, net, nltest, tasklist and an obfuscated ADRecon.ps1 script.              | MS-2024 (Initial access and reconnaissance) | T1059.001 PowerShell; T1082 System Information Discovery; T1482 Domain Trust Discovery; T1057 Process Discovery; T1087.002 Domain Account | Documented |
| 5. Installation  | Installed remote-management tools (AnyDesk, NinjaOne, Level.io) to keep access, tampered with security products through                                                                                      | MS-2024, MS-2025 (Cloud persistence)        | T1219.002 Remote Desktop Software; T1484.001 Group Policy Modification;                                                                   | Documented |

| Kill Chain stage                               | What Storm-0501 did                                                                                                                                                                                                                                                 | Source                                                                           | ATT&CK techniques                                                                                                                                                                                          | Basis      |
|------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|
|                                                | Group Policy, and in the cloud added a malicious federated domain to Entra ID as a backdoor.                                                                                                                                                                        |                                                                                  | T1484.002 Trust Modification                                                                                                                                                                               |            |
| 6. Command and Control (with lateral movement) | Ran Cobalt Strike beacons (launched with rundll32 and regsvr32) and moved on with stolen credentials. Used Evil-WinRM sessions to run commands on other hosts, ran DCSync against a domain controller, and used a compromised Entra Connect Sync server as a pivot. | MS-2024 (Credential access and lateral movement), MS-2025 (On-premises activity) | <a href="#">T1021.006 Windows Remote Management</a> ; T1021.007 Cloud Services; T1003 and T1003.006 DCSync; T1218.010 and T1218.011                                                                        | Documented |
| 7. Actions on Objectives                       | MS-2024: exfiltrated data with renamed Rclone to MEGA, then pushed Embargo ransomware through a GPO scheduled task. MS-2025: stole data with AzCopy, gave itself the Azure Owner role, deleted                                                                      | MS-2024 (Impact), MS-2025 (Exfiltration, Impact)                                 | T1567.002 Exfiltration to Cloud Storage; T1537 Transfer Data to Cloud Account; T1053.005 Scheduled Task; T1486 Data Encrypted for Impact; T1490 Inhibit System Recovery; T1485 Data Destruction; T1098.003 | Documented |

| Kill Chain stage | What Storm-0501 did                                                                               | Source | ATT&CK techniques                             | Basis |
|------------------|---------------------------------------------------------------------------------------------------|--------|-----------------------------------------------|-------|
|                  | snapshots and backups, encrypted storage with Key Vault keys, and extorted victims through Teams. |        | Additional Cloud Roles; T1657 Financial Theft |       |

Credential theft (T1003) sits in stage 6 because the stolen credentials are what let the actor move between hosts; the Kill Chain has no credential-access stage, which is one of the gaps discussed in Section 5.

#### 4. Where WinRM fits, and link to Weeks 2 and 3

T1021.006 is placed in stage 6 because an Evil-WinRM session gives the attacker remote command execution on an internal host, which is the "remote control" role the Kill Chain assigns to C2. MS-2025 reports that commands such as `sc query sense`, `sc query windefend` and `net.exe` ran over sessions started with Evil-WinRM, so the technique also carries stage 4-style discovery. It is a repeating internal step, not a single event, and that is exactly what a linear chain represents poorly. Note that Evil-WinRM is named only in the T1021.006 entry of the [G1053 page](#); it is not listed as a separate software object for the group.

Findings from the earlier weeks fit the chain as follows:

- **Week 2, Shodan (1.5M+ hosts with ports 5985/5986 open):** this measures exposed attack surface relevant to stages 1 and 3. It is not evidence that Storm-0501 scanned for or used exposed WinRM, because MS-2025 shows Evil-WinRM used inside an already compromised network.
- **Week 2, VirusTotal (Embargo sample, T1059, T1027, T1574, no T1021.006):** consistent with stage 7, since ransomware runs after lateral movement. The Rust compiler seen in VirusTotal also matches Microsoft's description of Embargo as a Rust-based strain (MS-2024, Impact).
- **Week 3, MISP:** the sample hash `f4ec2dba070a9ecd1dee342329b0cd7caa406cd4995c41b9aab9aea9b73cd06d` does not match either Embargo SHA-256 in the IOC table of MS-2024 (`efb2f645...` and `a9aeb861...`). The Week 3 caveat therefore stands: it is an Embargo-family sample with no confirmed link to Storm-0501.

#### 5. Kill Chain vs ATT&CK

The Kill Chain answers "how far has the intrusion progressed"; ATT&CK answers "what exactly did the attacker do and why". For Storm-0501 the two are complementary, but ATT&CK describes the campaign far better once the attacker is inside.

| Aspect            | Lockheed Martin Kill Chain                      | MITRE ATT&CK (Enterprise)                                                                              |
|-------------------|-------------------------------------------------|--------------------------------------------------------------------------------------------------------|
| Structure         | 7 linear stages                                 | <a href="#">15 tactics</a> (v19.2), each with many techniques and sub-techniques, not strictly ordered |
| Focus             | Perimeter breach and the path to the objective  | Attacker behaviour across the whole intrusion, including post-compromise                               |
| Lateral movement  | No stage; T1021.006 must be forced into stage 6 | Dedicated tactic (TA0008)                                                                              |
| Credential access | No stage                                        | Dedicated tactic (TA0006)                                                                              |
| Cloud activity    | Not addressed                                   | Covered (Entra ID and Azure techniques such as T1484.002, T1098.003, T1578.003)                        |
| Repetition        | Assumes one pass                                | Techniques can recur, as with repeated Evil-WinRM sessions between hosts                               |
| Best use          | Planning where to break the chain               | Detailed detection, hunting and coverage mapping                                                       |

Storm-0501 shows the gap clearly. Its 2025 campaign spends most of its time in steps the Kill Chain has no name for: credential theft, hopping between domains, privilege escalation in Entra ID, and cloud resource deletion. A defender relying only on the seven stages would see a long "Actions on Objectives" phase with no internal structure.

## 6. Defensive mapping

The course-of-action matrix below covers the five stages where the Storm-0501 evidence is strongest. "Destroy" is left out because it requires offensive action against the attacker. The Week 2 Shodan result, where port 5985 (unencrypted HTTP) accounts for about two thirds of exposed WinRM hosts, supports the Deny entries for stage 6.

| Stage       | Detect                                                                                          | Deny                                                  | Disrupt                                         | Degrade                                        | Deceive                                 |
|-------------|-------------------------------------------------------------------------------------------------|-------------------------------------------------------|-------------------------------------------------|------------------------------------------------|-----------------------------------------|
| 3. Delivery | Alert on sign-ins from known malicious IPs and on exploitation of CVE-2022-47966, CVE-2023-4966 | Patch public-facing servers; MFA on all remote access | Block known attacker infrastructure at the edge | Limit what a compromised edge server can reach | Decoy public service with WinRM exposed |

| Stage                      | Detect                                                                                                                    | Deny                                                                                                 | Disrupt                                                             | Degrade                                                                             | Deceive                                       |
|----------------------------|---------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------|-------------------------------------------------------------------------------------|-----------------------------------------------|
|                            | and CVE-2023-29300                                                                                                        |                                                                                                      |                                                                     |                                                                                     |                                               |
| 4. Exploitation            | Hunt for net.exe, nltest.exe, tasklist.exe and ADRecon-style scripts run by service accounts                              | Remove local admin rights; application control                                                       | EDR in block mode, tamper protection                                | Constrained PowerShell language mode                                                | Decoy domain accounts that alert when queried |
| 5. Installation            | Alert on new RMM tools (AnyDesk, NinjaOne, Level.io) and on new Entra federated domains                                   | Allow-list approved IT tools; restrict Global Administrator use                                      | Automatic remediation of unapproved tools                           | Remove the ability to add federated domains without approval                        | Canary admin account in Entra ID              |
| 6. C2 and lateral movement | WinRM Operational log, PowerShell logs 4103 and 4104, logon type 3 events, children of wsmprovhost.exe (Sigma rule below) | Block ports 5985/5986 from the internet; allow WinRM only from admin jump hosts; prefer HTTPS (5986) | Isolate the host when remote PowerShell runs outside change windows | Network segmentation; Just Enough Administration (JEA) limits what a session can do | WinRM-enabled honeypot hosts                  |
| 7. Actions on Objectives   | Azure activity alerts for role elevation, snapshot and storage deletion, and AzCopy exfiltration                          | Immutable storage, resource locks, Key Vault purge protection                                        | Suspend the compromised identity                                    | Offline backups outside the compromised tenant                                      | Canary files and storage accounts             |

The Detect and Deny entries for stage 6 follow from Microsoft's own detection list in MS-252, which includes "Suspicious remote PowerShell execution" for lateral movement with Evil-WinRM.

## 7. Limitations and conclusion

### Limitations.

- The chain merges two campaigns (MS-2024 and MS-2025). No single public incident covers all seven stages end to end.
- Reconnaissance is inferred. Public reports describe how access was obtained, not how targets were found.
- Storm-0501 changed from on-premises ransomware to cloud-based extortion, so one linear chain simplifies how the group operates.
- Technique mappings rely on the MITRE group page and Microsoft's descriptions; other vendors may map the same activity differently.
- The Week 2 sample (SHA-256 f4ec2dba...) has no confirmed link to Storm-0501.

**Conclusion.** Mapping Storm-0501 onto the Kill Chain shows that WinRM abuse (T1021.006) is a post-compromise technique used inside the network after credentials and administrator rights are already stolen, not an entry point. The Kill Chain is useful for seeing how far an intrusion has progressed, but it has no place for lateral movement or credential theft, which is where Evil-WinRM operates. ATT&CK fills that gap and gives the technique-level detail needed for detection, such as monitoring children of wsmprovhost.exe. The most effective defenses are therefore identity and network controls that break stages 3 and 6: patching exposed servers, enforcing MFA, and restricting WinRM to admin jump hosts over HTTPS.

### Sources

- [MITRE ATT&CK, Storm-0501 \(G1053\)](#)
- [MITRE ATT&CK, Enterprise tactics](#)
- [Microsoft Threat Intelligence, 26 September 2024](#)
- [Microsoft Threat Intelligence, 27 August 2025](#)
- Hutchins, Cloppert, Amin (2011), *Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains*, Lockheed Martin